

Notes of

Data Ethics and Data Protection

Mantelero and Vaciago's part

AY 2022/2023

The contents of the lectures and the lecture materials are summarized, revisited and organized to reflect the author's understanding, and there may be inaccuracies and errors.

The contents of this work are not intended for publication. Use at your own risk.

Table of Contents

1	27/02.....	6
1.1	Main differences between Common Law and Civil Law.....	6
1.2	Law does not equal justice.....	6
1.3	Sources of law.....	6
2	28/02.....	6
2.1	Part I: territorial partition, harmonization.....	7
2.2	Part II.....	8
2.2.1	Hard v. soft law, principle-based v. detailed regulation.....	8
2.2.2	Rule making and technology.....	8
2.2.3	The law of the horses.....	9
2.2.4	Prescriptive v. Preventive paradigm.....	9
2.2.5	Regulating tech in a risk society.....	10
3	06/03.....	10
3.1	Global society and technology.....	10
3.1.1	Transnational dimension.....	11
3.1.2	Trans-cultural dimension.....	11
3.1.3	(Regulatory) competition.....	11
3.2	Liability rules and technology.....	12
3.3	Data ethics.....	12
3.3.1	External point of view.....	13
3.3.2	Theory of technological mediation.....	13
4	07/03.....	13
4.1	Part I.....	13
4.1.1	Principles, the right to privacy.....	14
4.1.2	Pillars of the European approach to data protection.....	15
4.2	Part II.....	16
4.2.1	GDPR: introduction and scope.....	16
4.2.2	Definition of personal data.....	17
5	13/03.....	18
5.1	Categories of personal data.....	18
5.1.1	Judiciary data.....	18
5.1.2	Common data.....	18
5.1.3	Special categories of data.....	19
5.2	Recital 26 GDPR (identifiable natural person).....	20
5.2.1	Non-personal data.....	21
5.2.2	Main principles of personal data processing.....	21
6	14/03.....	21
6.1	Data processing.....	22
6.2	Four pillars of the GDPR.....	23
6.3	Personal data processing activities.....	24
6.4	Child consent.....	24
6.5	Legitimate interest.....	25
7	20/03.....	26
7.1	Individual user's point of view and rights.....	26
7.2	Sanctions.....	28
8	21/03.....	28
8.1	Part I.....	29
8.1.1	GDPR Compliance.....	29
8.1.2	Task distribution.....	29
8.1.3	Data protection officer.....	30

8.1.4 Accountability of the controller.....	31
8.2 Part II, III.....	32
8.2.1 Security of data in the context of accountability (Art. 32 GDPR).....	32
8.2.1.1 Risk assessment.....	34
8.2.1.2 Data protection impact assessment.....	34
8.2.2 Data breach.....	35
8.2.2.1 Obligations in the case of a data breach.....	35
8.2.2.2 Data breach register.....	36
9 28/03.....	36
9.1 Data protection impact assessment (example cases).....	37
9.2 Biometric data.....	38
9.3 Large-scale project management I.....	39
10 03/04.....	39
10.1 Italian DPA and OpenAI in Italy.....	39
10.2 Large scale project management II.....	40
10.3 Regulatory competition.....	41
11 04/04.....	41
11.1 Regulating AI I, ethics of AI.....	41
11.2 Regulating AI II, impact on human rights.....	43
12 13/04 Regulating AI III, risk-based approach.....	44
13 17/04.....	45
13.1 Regulating AI IV, the ethical approach in practice.....	45
13.2 Exam question example (Mantelero).....	46
14 Io vetrai, tu vestrasti, egli.....	48

Cases index

No smoking.....	8
Online defamation. From publishers to ISPs.....	9
Armani (rule making, prescriptive v. preventive paradigm).....	9
Cookies (rule making, prescriptive v. preventive paradigm).....	10
E-bay (transnational dimension).....	11
Costeja (balance of interests).....	15
Mosley (balance of interests).....	16
Dynamic IP Address I (common data).....	18
Dynamic IP address II (common data).....	19
Sexual orientation (special categories of data).....	20
Identification via camera (personal data, Recital 26).....	20
Lindqvist (household activity).....	22
Buivids (household activity).....	23
Cookie walls.....	24
Claudia's pizza (legitimate interest).....	25
Video surveillance (legitimate interest).....	25
Osterreichische Post (right of access).....	26
BPER Banca (right to be forgotten).....	26
Caffeina Media, Google Analytics (data transfers to the US).....	27
Immuni (pseudonymized data).....	28
OneDirect (inability to exercise rights).....	28
Vodafone (aggressive telemarketing).....	28
WindTre (overly aggressive marketing).....	28
GLOVO Spain (data protection officer).....	30
Giessegi (lack of data processing agreement).....	31
ISWEB (lack of authorization to engage a sub-processor).....	31
Jehovan todistajat (joint-controllership).....	31
Enel (accountability).....	32
Rousseau (security).....	33
Smart factory (example of data protection impact assessment).....	37
Piedmont's smart public transport system (example of large scale project).....	40

1 27/02

Law and technology

The legal system is complex because it's a patchwork: it is ^{قلمرو}territory-based. However, different countries may have similar frameworks. This is because law is a product of society, and similar societies will produce similar pieces of legislation.
^{قانون گذاری}

1.1 Main differences between Common Law and Civil Law

[see notes on slides]

1.2 Law does not equal justice

[see notes on slides]

The goal of the law is to reduce the potential conflict without resorting to violence. In order to have this effect, the law must be binding. On the contrary, ethics is not binding.
^{توسیل به خشونت}
^{الزام آور}

1.3 Sources of law

The legal requirements come from laws but also contracts and any other document relevant to the case in question.

Players in law:

1. ^{قانونگذاران}*Legislators*: more important in the Civil Law systems.
2. *Courts*: more important in the Common Law systems.
3. *Legal scholars*: they review the decisions of the legislators and the courts, and make up for the fact that the legislators and the courts do not have time to discuss the legal issues on an academic level.
4. *International law firms*: they act at the global level and shape the contracts that are issued by big multinationals. The contracts issued by Google, for example, will regulate a big part of the international digital market.
^{صادر شده توسط}

Clearly, the relationship in terms of strength between these actors is not peer-to-peer.

Note that in Common Law systems the legislator is acquiring power. In fact, it is impossible to regulate new tech with case law.

2 28/02

Law, design & responsible innovation

The emerging of data ethics in the debate on data science

2.1 Part I: territorial partition, harmonization

The legal framework is partitioned territorially, but not only in terms of countries: there can be some bodies which promote international agreements that bind multiple countries; there are laws that are only valid regionally within a country (especially true in federal states).

Inside the one state, the regional and national laws have the same force, binding nature. ^{طبیعت الزام آور}

Internationally, if you (state) let an international body discuss a piece of law for your own territory, you must accept to give up some power. This is necessary if some issues are not only national: an example is data protection regulation; another example is cybercrime. In general, all the international agreements (treaties, conventions) need to be implemented by local states. There is always a need for state-wise implementation.

In the case of the EU, the EU framework allows for more flexibility. The EU can issue ^{می تواند صادر کند}

1. A directive: it must be implemented by the states. This allows for a slow transition towards harmonization. ^{بخشنامه}
2. A regulation: it is immediately applicable without local implementation. ^{مناسب، قابل اجراء}

So there isn't always a need for state-wise implementation.

The goal of the EU is to create a common market which allows for the free flow of goods and people. A limitation to create a common market is given by the difference in regulations in different countries. Hence, from a legal perspective, the goal of the EU is to harmonize the legal (regulatory) framework in different countries. ^{از این رو} Harmonization does not apply to all aspects of society. Some aspects of society are strictly related to the structure of society, which may vary from country to country (eg, family law). ^{مؤکدا} The harmonization at a European level has the main goal of creating a common market. This *sometimes* results in a protection of fundamentals rights, but in practice this is generally not the main goal.

An example of harmonization is the case of data protection. Initially, there are many countries with different regulations or no regulation at all. Any country-representative wants that the EU regulation will reflect the regulation of his/her country. To prevent any country from having a strong competitive advantage, a directive is issued first, so countries have time to harmonize. Then, a regulation is issued, which is immediately a source of law. There are cases where a regulation is issued immediately. For example, this is applicable for very technical issues (like air traffic control). ^{مسائل}

There is another instrument in the EU framework: the *act*. This is not used to promote harmonization, but to *prevent divergence*. ^{واکرایبی} The act is released before significant regulation is created by the countries. For example, this strategy may be used for regulating AI. The tool of the act changes dramatically the power of member states with respect to the EU. ^{به طور چشمگیری} With the act, the EU becomes a regulatory body that anticipates the member states, rather than working with the regulations that are already in use. ^{تبدیل می شود}

Important: from the point of view of the application, the act is immediately applicable, just like a regulation. What constitutes the difference between an act and a regulation is the *reason* why it is issued. ^{نقطه نظر}

What about deterrence from non-compliance? ^{عدم انطباق} In the case of directives, there are economic sanctions for non-compliance. ^{تحریم ها} In the case of regulations, they immediately outrank national law and legal non-compliance is not possible. However, it is often a problem to decide whether a piece of

EU law applies to a specific case: for example, the AI act applies to high-risk applications: but what is an high-risk application?

Finally, Lex posterior and lex specialis are other principles used to solve (non-territorial) conflicts between different sources of law. Lex posterior is the principle according to which a later piece of legislation prevails on an older one. Lex specialis is the principle according to which a more specific piece of legislation prevails on a more general one.

2.2 Part II

2.2.1 Hard v. soft law, principle-based v. detailed regulation

The regulations do not come only from the governments, local governments or international governments. This is “top-down” law. There is also a bottom-up approach, usually referred to as “soft” law. This arises from a spontaneous convergence of the main actors in a given sector, which regulate themselves and agree to comply to some rules.

State (top-down) laws require time to be created. They must pass through the political arena. They are difficult to change and are made by people who are usually not familiar with the technical issues (the politicians). They are, however, stronger in terms of enforcement.

Soft laws are made by the companies / stakeholders which are big players in a sector. They know exactly what are the technical issues, and have more resources to discuss their own issues. Of course, the goals of the law born in this way depends on the composition of the actors with a seat at the table of negotiations (only companies or also customers? What are the interests of different companies?) Soft law is also quicker to be elaborated and come into effect. However, it is weak in terms of enforcement. The deterrence against non-compliance might come “only” in the form of damage of reputation, which is not a big deal for a large player.

Because these two approaches have complementary positive aspects, they are usually combined. A top-down law requires to implement some key principles, and fixes the key values. Then, the details are left to the soft law that nonetheless benefits of the enforce-ability of the top-down law.

A similar approach is to set the principles from which the technological standards descend by hard law (principle-based regulation), rather than setting the standards by law (detailed regulation), then constitute an authority designated to define the technological standards.

2.2.2 Rule making and technology

The role of technology in shaping the rules is important. Tech can be regulated but can also be used to regulate. In the digital context, the *code* can shape the technology that shapes the rules. As example, consider the following case.

Case: No smoking

We want to reduce the number of smokers. How?

Increase taxes → work on the *market*. ^{جنبہ منفی}Downside: there are people who will keep buying cigarettes.

Forbid smoking in public areas → use the *legal instrument*. Downside: the law is sometimes difficult to implement.

Change the culture → work on *social norms*. This is very effective but takes a lot time.

Install smoke detectors → Use *technology*. This can be very effective and can be implemented quickly.

2.2.3 The law of the horses

Why do we want to regulate tech? Is it even necessary? “Horses exist without our regulation.”

Issue: new rules must not create conflict with existing rules. In general, to avoid this problem, one must always ask whether it is really necessary to regulate a new piece of tech. For example, we did not have to regulate defamation from scratch when internet came around, but only those special aspects of defamation via internet.

Case: Online defamation. From publishers to ISPs.

First, let's examine cases by analogy with existing laws (pre-internet):

Cubby Inc. v. CompuServe Inc. [third party daily newsletter] → the ISP has no responsibility over the content that is delivered over the Internet, just as a newsstand has no responsibility for the content of the newspapers it sells (it is “only a distributor”).

Stratton Oakmont v. Prodigy Services Co. [moderated bulletin board] → the moderators are liable for the content they moderate, just as a publishers are liable for the content written by their authors.

This analogy with the pre-internet world creates a paradox: *no moderation* is rewarded with less liability. A “law of the horse” is necessary!

The US adopted the Communication Decency Act 1996 and the Digital Millennium Copyright Act 1998. The EU adopted the Directive 2000/31/EC.

2.2.4 Prescriptive v. Preventive paradigm

Behavioral rules are in the form “you must do this” (a *prescription*). This is enforced by police, governments... But in the digital context the enforcement is much more difficult. Hence, technology-embedded rules (*preventive*) are very important. They must complement the prescriptive (behavioral) rules. In other words, relying only on the ex-post-facto approach is too expensive; rather than spending a lot of money to prosecute cybercriminals in foreign countries, it is better to mandate the adoption of IT safety rules.

However, using technology to enforce rules is not a one-to-one correspondence. The law is too nuanced and subject to interpretation to be coded deterministically. As a consequence, using technology to enforce rules is not a neutral approach: it creates more rules.

Case: Armani (rule making, prescriptive v. preventive paradigm)

The DNS is designed so that `armani.it` can route to only one website. However, the first-come-first-serve approach that is usually implied by this technology is not always appropriate. In the case of Armani, a recognized brand, the brand had to fight in court to acquire its domain name which was registered by a fridge reseller with the same name.

Case: Cookies (rule making, prescriptive v. preventive paradigm)

The opt-in/out scenario can be damaging if the users are not informed on the choice, even though it leaves more flexibility. Legally, a user's consent should be clearly informed, but the choice of the concrete implementation of the consent (checking a box, clicking a big green button that says "OK", scrolling through the terms and conditions and only then activating the button...) are not equivalent from the point of view of how much the user base will be informed.

2.2.5 Regulating tech in a risk society

We live in a risk society. In the past, the risks were always the same. Now (since the industrial revolution) the sources of risk are increased enormously.

Preventing risk comes from design, but also from *risk assessment and management*. If you create a technology that gives rise to risk, you must assess the risk and pay for (some of) the consequences. Specifically, the concept of liability will be explored later.

Sometimes, the risk assessment is difficult. In these cases, the precautionary principle is adopted. It means that: if a piece of technology is able to affect a society negatively and in an unknown way, it is better to mandate that the piece of technology does not enter the market. However, research and investment are still possible. So, this paradigm can be summed up as follows: risk assessment, if possible, and no marketability otherwise.

3 06/03

Law & ethics

The role and limits of the ethical approaches

Recap:

Law can be used to shape technology, but technology can also be used to create and enforce rules, hence "making law" in the by-design approach.

Shaping technology can happen not only by the state law (top-down) but also via agreements between the big players (bottom-up, or soft law).

Risk assessment is necessary; when it is not possible, the risk is not manageable and the product should not be marketed.

3.1 Global society and technology

When we discuss data regulation, our focus will be on the EU. But the EU is not the only big player / geographical area, for example there are the US or China, Russia... It is important to keep an open mind when discussing with these other actors.

The shape of society can shape the regulation of technology. In this regard there are three dimensions:

1. Transnational dimension
2. Trans-cultural dimension

3. Regulatory competition

3.1.1 Transnational dimension

The regulations may have an impact on the merchantability of given products, because of nonconformity. On the one hand, some digital products can be easily distributed all over the world; on the other hand, there is an increasing risk that some regulatory provisions and protections applicable to a given product in a given country, may not apply in other countries (eg copyright).

Case: E-bay (transnational dimension)

Selling Nazi books in France is illegal. If these books are sold on E-bay, they are sold in many countries and may inadvertently be sold in France even if they originate in another country.

Example: Copyright

Copyright is protected almost everywhere in the world, but enforcement is very different from country to country. Blocking internet flows is much harder compared to blocking other global networks. Legal consequences are also much harder to enforce in a foreign countries.

Example: EU power outside the EU

Because technological legal issues are so affected by the trans-national dimension, the EU has had a sort of extra-territorial approach: the EU asks providers in other countries to adopt EU regulations. This approach is of course limited by the limited power of the EU.

3.1.2 Trans-cultural dimension

Especially when it comes to moderation of content, the cultural dimension can strongly affect the results. Behavior that is offensive somewhere may not be elsewhere. Take for example the concept of “defamation”: what we consider “a joke” may be taken as in insult, an attempt to defamation, in other countries. Through terms and conditions, providers decide what to allow / block according to the culture of their society, which causes a cultural conflict when their product is merchandised abroad.

Example: Facebook and breasts

Facebook took down paintings and other pieces of art depicting women’s nude breasts.

Example: AI labelers, moderators

Labelers are necessary to create datasets to train AI, and human workers are necessary to provide moderation to social networks. This arises several work-ethics concerns (is it ethical to let people sit in front of shocking images for hours on end?) This concerns are resolved very differently in different parts of the world.

3.1.3 (Regulatory) competition

The variety of rules in different countries (because of the trans-national and trans-cultural barriers) creates the so-called regulatory competition, where each actor tries to obtain the role of the global regulator for its technology of interest. In the case of data, the EU has become a leader in regulating data protection.

3.2 Liability rules and technology

Criminal liability applies *mostly* to physical persons. There are examples of criminal liability in corporate law, but usually criminal law targets people. On the contrary, administrative liability ^{اداری، اجرایی} targets also companies and is a softer form of liability (usually involving only fines, not jail or other sanctions).

Criminal and administrative liability are focused on the idea of acting in the public interest. If someone is put in jail or asked to pay money, this does not solve the damage they have created, it only serves the purpose of deterring other potential criminals.

To recover the damage, it is necessary to act via the civil law, which determines the retribution of the victim. The civil law action must be presented separately by the damaged parties.

Now, how do we determine civil liability? ^{تعیین کردن، مشخص کردن} An extreme is the approach in which the entity who creates the damage is always liable; this creates a huge burden on the shoulders of those that create the damage. Rather, the traditional approach is based on fault: you are liable because of your intention of wrongdoing or your negligence ^{غفلت}. But this approach does not work well in the case of technology: sometimes, a malfunctioning of a machine cannot be attributed to anyone in particular (consider the case where all precautions were taken and all regulations applied carefully); sometimes, it is possible to target one specific person at fault (like an engineer) and not the entire company, but an individual is usually unable to repay the damages that machines may make. ^{کل} Therefore, the problem of repaying the victims is still unsolved. For this reason, in the corporate or industrial context we adopt *strict liability*: the company is liable because it created a risk, even if it is not at fault. The rationale is that the company is in the best position to control the risk. However, a threshold must be set to counteract the main side effect of strict liability, the so-called “chilling effect”: investors will not invest in the new technologies with unknown risks, because of the high burden of strict liability, thus preventing the advancement of technology.

The solution that we adopted is to apply strict liability, but with possible derogation. For instance, if you are compliant with some standards (eg, risk assessment and management procedures) you are exempt from liability: this provides a sort of “exit strategy”. Other solutions can require the use of insurance policies in order to be exempt from liability: in this case, we use strict liability but shift the cost to the insurance.

3.3 Data ethics

Data ethics is a subtopic of ethics of technology, just as data protection is a subtopic of technological regulation. A debate on data ethics has flourished mostly in the context of AI. Outside, it has remained mostly an academic discussion. Ethics of technology is different from technological regulation because it ^{شکافا شد} encompasses ^{را در بر می گیرد} broader aspects, such as the relationship between humans and the technology they create, and the definition of an ethical development and use of technology.

3.3.1 External point of view

The initial point of view on ethics of technology has been “external”. Technology was considered as something that one can see, judge, etc. This point of view has shown its limits when we realized that technology is not neutral, but shapes societies just as it is shaped by society. However, even from this limited point of view, it is clear that not everything that is technically feasible can be considered ethically acceptable.

3.3.2 Theory of technological mediation

Then, another point of view came to light. Technology is no longer something that we look at and judge, but has a circular relationship with society. Technology has an impact on society, not only society on technology; as a consequence of this double relationship, technology can be thought of as “mirror” of society.

When judging a piece of technology, we must consider not only how good or bad it is “in a vacuum”, but also how good or bad the way it shapes society is, and how good or bad the way it was shaped by society is. If a piece of technology arises from certain (eg, racial) views of society, this should be taken into account when judging the technology. If a piece of technology impacts society so that certain (eg, racial) views of society are reinforced, this should be taken into account. For example, the idea that one requires a smartphone to live in the city is a very specific view of society; it shapes the design of technology, to make it more wearable and comfortable, but it is also reinforced / shaped by technology, in the sense that the more people carry and use smartphones, the harder it is not to carry and use one. From an ethical standpoint, we cannot only take into account that smartphones simplify some aspects of our lives.

Crucially: technology is not neutral. When you design something, you always design with your mindset. Intentionally, or unintentionally, you reflect your views in the technology. Values are embedded in the technology. The theory of technological mediation states that technology mediates the behavior of people in society. For example, now it is possible to consider abortion in case of diseases of the fetus: technology changed the way we make such important decisions. Thus it is clear how technology is not only shaped by, but also shapes, our values.

In the end, the main risk in new a piece of technology is that of an unintentional bias, which cannot be detected by the creator of the technology.

4 07/03

Data protection and the GDPR

GDPR: definitions, nature and implementation, territorial scope, principles, legitimate grounds.

4.1 Part I

[Professor Vaciago introduces himself.]

He thinks the mindset of engineers is the best one, because lawyers create problems, while engineers solve them. However, he is changing his mind about data scientists ☺ : sometimes they need lawyers.

4.1.1 Principles, the right to privacy

Who are Warren and Brandeis? They are two lawyers who wrote the iconic article “The right to privacy” in Harvard Law Review, about one hundred years ago. It remarked the importance of “the right to be alone”:

a principle which may be invoked to protect the privacy of the individual from invasion either by the too enterprising press, the photographer, or the possessor of any modern device for recording or reproducing scenes or sounds

Art. 12 of the Universal Declaration of Human Rights:

No one shall be subjected to arbitrary interference with his privacy, family, home or correspondence, nor to attacks upon his honor and reputation. Everyone has the right to the protection of the law against such interference or attacks.

Art. 8 of the European Convention on Human Rights:

Right to respect for private and family life.

1. Everyone has the right to respect for his private and family life, his home and his correspondence.
2. There shall be no interference by a public authority with the exercise of this right except such as in accordance with the law and is necessary in a democratic society in the interests of national security, public safety or the economic well-being of the country, for the prevention of disorder or crime, for the protection of health or morals, or for the protection of the rights and freedoms of others.

Art. 8 of the European Convention on Human Rights is at the basis of the GDPR (important for the exam!)

What about point 2 of article 8 of the European Convention on Human Rights? It is the expression of the *balance of interests*. For example: on the one hand, there is public security. On the other hand, the right to privacy. CCTV can be an attack to individual privacy. The balance of interests is a constant in law.

Art. 8 of the Charter of Fundamental Rights of the European Union:

1. Everyone has the right to protection of personal data concerning him or her.
2. Such data must be processed fairly for specified purposes and on the basis of the consent of the person or some other legitimate basis laid down by law. Everyone has the right of access to data which has been collected concerning him or her, and the right to have it rectified.
3. Compliance with these rules shall be subject to control by an independent authority.

This article is a summary of what is data protection in the European Union.

It is important to notice that the legitimate basis to process data is not only the person's consent, but there may be other legitimate basis (always mediated by the balance of interests). The right to access and rectification is crucial in technical contexts. If there is not a proper data indexing tool, some entities may have a hard time retrieving a person's data. Deleting data can be equally difficult

for the same reason. Furthermore, there must be a data protection authority that makes sure that these principles are applied.

منشور

Art. 52 of the Charter of Fundamental Rights of the European Union:

1. Any limitation on the exercise of the rights and freedoms recognized by this Charter must be provided for by law and respect the essence of those rights and freedoms. Subject to the principle of proportionality, limitations may be made only if they are necessary and genuinely meet objectives of general interest recognized by the Union or the need to protect the rights and freedoms of others.

شناخته شده توسط

ذات

[...].

The principle of proportionality is the balance of interests: you have to balance, proportionally, the fundamental rights of people.

4.1.2 Pillars of the European approach to data protection

The pillars are: *a data-centric model, procedural approach, tech neutral approach, risk management, legal basis*. Risk management is what determines the result of the balance of interests.

Employing a tech neutral approach means working on the principles that govern technology, regardless of the technology that is regulated and the technical implementation details. However, so far in data protection law there is a lot of stress over the necessity of human intervention, which is obviously not tech-neutral (ie, “human intervention” can be considered a type of technology in itself).

Case: Costeja (balance of interests)

CJEU, C-131/12, Google Spain SL, Google Inc. v. Agencia Espanola de Proteccion de Datos (AEPD), Mario Costeja Gonzalez, 2014

There are two main courts in Europe, but:

1. European Court of the Human Rights → Does not only operate in the EU
2. European Court of Justice → It is a EU institution

This case was discussed by the ECJ. It concerns the indexing of information on Google with respect to the privacy of a given individual. Google has implemented a tool that helps users ask for the de-indexing of information, as a result to this case.

Mr Costeja Gonzalez lodged a complaint against La Vanguardia, which published a daily newspaper, and against Google Spain and Google Inc. The complaint was based on the fact that Google had indexed an article published by La Vanguardia that reported an episode (actually happened) that put Mr Costeja Gonzalez in a bad light. The conflicting interests begin to emerge: preserving information about real events that have happened versus preserving the privacy (and reputation) of people.

شکایت

حفظ کردن

The resulting decision of the court was to:

1. reject of the complaint towards La Vanguardia
2. uphold the complaint towards Google

حفظ کردن

La Vanguardia had a right to publish the article because it was in the public interest at the time. But the indexing by Google has no value for the public interest nowadays, so it is forbidden by the law.

4.2 Part II

[Presentation of the right-to-removal tool of Google]

Case: Mosley (balance of interests)

ECtHR, Mosley v. The United Kingdom, No. 48009/08

From the slides:

A British national weekly newspaper, News of the World, published a front page article about Max Mosley, a well known figure in the International Automobile Federation and Formula One, reporting his alleged “Nazi” sexual activities and including intimate photographs, taken from secretly recorded videos.

The Court recognizes that the private life of celebrities have become a lucrative ^{سودآور} commodity for certain sectors of the media. The publication of news about such persons contributes to the variety of information available to the public and, although generally for the purposes of entertaining ^{سرگرم کننده} rather than education, it benefits from the protection of ^{آزادی بیان} freedom of expression.

However, such protection may ^{واگذار کردن} cede to the requirements of the right to privacy, where the information at stake is of a private and intimate ^{صمیمی} nature and there is no public interest in its dissemination.

4.2.1 GDPR: introduction and scope

The General Data Protection Regulation is a EU regulation (2016/679), a legal framework that sets *guidelines for the collection and processing of personal information of individuals who live in the EU*. Its goals are: manage control and protection of personal data.

Art. 1 of the GDPR:

1. This regulation lays down rules relating to the protection of *natural persons* with regard to the *processing of personal data* and rules relating to the *free movement of personal data*.
2. This regulation protects *fundamental rights and freedoms* of natural persons and in particular their right to the protection of personal data.
3. The *free movement of personal data* ^{در داخل} within the Union shall be neither restricted nor prohibited for reasons connected with the protection of natural persons with regard to the processing of personal data.

Note that the free movement of personal data is protected. Also, note that the GDPR applies only to the protection of physical persons. Legal entities which are not physical persons are *not* protected by the GDPR, but have to apply it when they process personal data belonging to physical persons. **For example:** if a company processes the information of another company, there is no application of the GDPR.

Furthermore (and less intuitively), **physical persons in general do not have to follow the GDPR**. The regulation applies only to legal entities that are not physical persons. A physical person that uses the information of a friend is not sanctionable under GDPR (but other existing pieces of legislation). ^{قابل تحریم}

Who is affected by the GDPR? All businesses collecting or holding personal data on people who are located in EU and EEA, regardless of their residence or their citizenship.

Territorial scope: companies that are not established in the Union but are subject to the GDPR shall designate a representative in the Union (Article 27 GDPR). The representative is not responsible for breaches of the GDPR by the business it represents (liability is not outsourced).

Art. 3 of the GDPR:

(1) This regulation applies to the processing of personal data in the context of the activities of an establishment of a controller or a processor in the Union, regardless of whether the processing takes place in the Union or not.

(2) This regulation applies to the processing of personal data of data subjects who are in the Union by a controller or processor not established in the Union, where the processing activities are related to:

- The offering of goods or services, ^{صرف نظر از} irrespective of whether a payment of the data subject is required, to such data subjects in the Union; or
- The monitoring of their behavior ^{تا آنجایی که} as far as their behavior takes place within the Union.

The Art. 3 is basically the same principle of territorial scope described above. However, notice that if a processor or controller has any kind of establishment in the Union, it is subject to the GDPR even if it is not processing personal data of people in the Union and even if such processing does not take place in the Union.

An example is provided by the Costeja case: Google is bound by the GDPR because the data treated belongs to a person located in the Union. The simple way to answer the territorial scope question is: **the GDPR applies to any legal entity that provides services in a member state of the EU.**

4.2.2 Definition of personal data

Art. 4 GDPR:

“Personal data” means any information relating to an identified or identifiable natural person (“data subject”); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as name, an identification number, location data, an online identifier or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural or social identity of that natural person.

So, what is personal data? Any data that could *directly or indirectly* identify someone.

An interesting fact is that an IP address is a piece of personal data too, and is regarded as a possible identifier, even though it is not always possible to identify a person by their IP address.

5 13/03

GDPR: Task distribution (DC, DP, JC, DPO), Accountability.

Recap of the previous lecture:

Principle of balance of interests, the right to be forgotten and its relationship with the balance of interests. The definition of privacy according to Warren and Brandeis. The definition of personal data.

Today we will discuss about the concept of personal data.

5.1 Categories of personal data

There are three main categories of personal data:

1. Common data
2. Special categories of data
3. ^{قوه قضائیه} Judiciary data

The distinction between these three categories is important because their private nature is regarded differently. ^{در نظر گرفته شده است}

5.1.1 Judiciary data

As for judiciary data, it can be considered to be the most sensitive. However, this data is treated very differently in different cultures. In the US, it is possible to know whether anyone has committed a crime. In Europe, this is quite the opposite: not only one cannot ask for the criminal record of anyone, but even an employer is not allowed to ask to a perspective employee whether they have or have not committed a crime.

5.1.2 Common data

Name	Address	Phone
Bank / Credit cards	Email address	IP address
Cookies	Online identifies	...

Case: Dynamic IP Address I (common data)

C-70/10 – Scarlet Extended v. SABAM

An association of music and film industries in Belgium decided to start a systematic monitoring of network traffic on p2p networks, to counteract ^{مقابله کند} illegal sharing of copyrighted material.

From the slides:

It is common ground, first, that the injunction requiring installation of the contested filtering system would involve a systematic analysis of all content and the collection and identification of users' IP addresses from which unlawful content on the network is sent. Those addresses are protected personal data because they allow users to be ^{مورد مناقشه قرار گرفت} precisely identified. ^{غیر قانونی} ^{دقیقاً}

In other words, the court decided that such a systematic monitoring would require the collection of common data and is therefore illicit. ^{فاجاق}

In Italy, it is necessary to have an injunction ^{دستور} from the judge to be authorized to know the information about who is using a given IP address at a given time; this information is kept for 5 years. However, in most EU member states, this information is not even retained by the telecommunication authority. In Italy, this choice is justified by the anti-terrorism legislation. ^{حفظ شده توسط} However, this information is used for reasons that are broader than countering terrorism. The fact that the IP address can be used, in some contexts, to precisely identify someone, is sufficient ground to consider it a piece of (common) personal data.

Case: Dynamic IP address II (common data)

C-582/14 Breyer v. Bundesrepublik Deutschland

From the slides:

It must be determined whether the possibility to combine a dynamic IP address with the additional data held by the internet service provider constitutes a means likely reasonable to be used to identify the data subject.

It appears that the online media services provider has the means which ^{ممکن است به احتمال زیاد} may likely reasonably be used in order to identify the data subject, with the assistance of other persons, namely the competent authority and the internet service provider, on the basis of the IP addresses stored.

In this case, for the first time the ECJ mentioned explicitly the possibility of requesting the IP address to the ISP as a basis to consider it personal data.

5.1.3 Special categories of data

Regarding special categories of data, some examples are:

1. Biometric data
2. Genetic data
3. Health data

These are universally considered special categories of data. However:

1. Racial or ethnic origin
2. Political opinions
3. Religious or philosophical beliefs
4. Trade union membership
5. Sexual orientation

These are not universally considered special categories of data or even personal data. However, they are in Europe.

Case: Sexual orientation (special categories of data)

C-184/20 – OT v Vyriausioji tarnybinės etikos komisija (Chief Official Ethics Commission)

From the slides:

Lithuanian case concerning national anti-corruption legislation. A person subject to this legislation was obliged to make a “declaration of private interests” to the Lithuanian administrative authorities, including information about his acquaintances and relatives for the purpose of identifying potential conflicts of interest.

Results:

The sensitive nature of data is “not only of inherently sensitive data, but also of data revealing information of that nature indirectly, following an intellectual operation involving deduction or cross-referencing.” Therefore, “the publication of personal data that are liable to *disclose indirectly* the sexual orientation of a natural person constitutes processing of special categories of personal data.

This case teaches us that even when requiring personal data for a legitimate reason, there is the possibility of causing the disclosure of special categories of data.

Example: Drunk picture

An image of a drunk person is common data or special categories of data? It is important to motivate the answer. The answer of professor Vaciago: can this picture be regarded as health data? If we go in this direction, the amount of health data that can be collected just by looking at a person becomes huge (eg, are they wearing glasses?) To avoid this problem, we can define “health data” only those pieces of information that are naturally hidden.

5.2 Recital 26 GDPR (identifiable natural person)

From the GDPR Recital 26:

To determine whether a natural person is identifiable, account should be taken of all the means reasonably likely to be used, such as singling out, either by the controller or by another person to identify the natural person directly or indirectly. To ascertain whether means are reasonably likely to be used to identify the natural person, account should be taken of all objective factors, such as the costs of and the amount of time required for identification, taking into consideration the available technology at the time of the processing and technological developments.

This recital is very important because it clarifies the principles to determine whether a person is identifiable or not by means of the data given. The cases of Breyer and SABAM were connected to the identification via IP address. In the future, it may be simpler to identify a person and there may be more means (notice how the this approach is indeed tech-neutral).

Case: Identification via camera (personal data, Recital 26)

C-212/13 Frantisek Rynes v. Urad pro ochranu osobnich udaju (Office for personal data protection)

Does monitoring a public space with a camera for the purpose of protecting one's own property (in this case, a house) amount to processing of personal data? The Court held that the image of a person recorded by a camera system constitutes personal data, since with one's image it is possible to identify the person.

5.2.1 Non-personal data

The free flow of non-personal data is regulated by Regulation (EU) 2018/1807, while the Regulation (EU) 2016/679 (aka GDPR) regulates the flow of personal data.

From the GDPR recital 26:

The principles of data protection should therefore not apply to anonymous information, namely information which does not relate to an identified or identifiable natural person or to personal data rendered anonymous in such a manner that the data subject is not or no longer identifiable.

^{مصنوعي} Synthetic data is the future, according to professor Vaciago: ^{تفسير} this refers to the operation of rendering the data useless for the purpose of direct or indirect identification, while retaining much richer information than anonymous data. Synthetic data is a middle ground in terms of data quality between anonymous data and personal data, without being subject to GDPR.

There is no EU prescriptive technical standard for anonymization. It is necessary to do a contextual analysis. In particular, one must take into account the risk that further developments in technology will make de-anonymization possible in the future, where it would not be possible today (eg, quantum computing). Because of the complexity of this analysis, many companies decide to delete the personal data they hold.

All in all, there are four possibilities:

- Keeping personal data
- Anonymizing personal data
- Creating synthetic data from the original personal data
- Deleting personal data

5.2.2 Main principles of personal data processing

Lawfulness and transparency

^{قانونمندی و شفافیت}

Purpose limitations (data should be collected for specified, explicit and legitimate purposes).

Data minimization (in function of the purpose).

Accuracy

Storage limitation (in time and space).

Integrity and confidentiality

These principles are important to use at the exam.

6 14/03

GDPR: Security, accountability, risk assessment

Today, we will discuss about accountability. Accountability is a basic and fundamental principle in the GDPR. From the slides:

The controller shall be responsible for and be able to demonstrate compliance with the above principles.

With reference to the “main principles of personal data processing” tabulated above.

Accountability means that a new business is accountable for its decisions with regard to the GDPR: for example, a business can decide that consent is not required for their processing, as long as they can justify their choice with respect to those principles. This approach accounts for the flexibility necessary when dealing with data in a quickly changing technological landscape. This is an instance of the principle-based approach described earlier.

6.1 Data processing

From the slides:

“Processing” means any operation or set of operations which is performed on personal data or on sets of personal data, whether or not by automated means, such as collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, disclosure by transmission, dissemination or otherwise making available, alignment or combination, restriction, erasure or destruction.

Data processing regarding a purely personal or household activity carried out by private individuals does not fall under the GDPR. However, the so-called “household exemption” is interpreted narrowly. It could happen that a physical person could be charged in violation of the GDPR: this is an exception to the general rule that only legal entities that are not physical persons are bound by the GDPR.

Case: Lindqvist (household activity)

CJEU, C-101/01, Case Bodil Lindqvist

Mrs Lindqvist published a webpage that gave information about her church, containing personal data of her catechist colleagues, as part of a personal project for a data processing course she was following. Her colleagues did not appreciate and she was criminally accused for illegal processing of personal data.

Mrs Lindqvist claimed that the household exception applied, but the CJEU excluded the exception, stating that it relates only to activities carried out in the course of private or family life, and never through publication of data on the internet so that it is made accessible to an indefinite number of people. Besides, notice: the information regarding religious faith is special category of data.

The fact that data protection lawsuits can lead to a criminal proceeding is only possible in some countries in Europe (but not all). Among these, Sweden.

From the court:

The act of referring, on an internet page, to various persons and identifying them by name or by other means, for instance by giving their telephone number or information regarding their working conditions and hobbies, constitutes the processing of personal

data wholly or partly by automatic means within the meaning of Article 3(1) of Directive 95/46/EC.

Such processing of personal data is not covered by any of the exceptions in Article 3(2) of Directive 95/46/EC.

So, to summarize: the exception to the GDPR (household exception) does not apply to all physical persons, but only to those instances of data processing carried out by physical persons that fall within the limits of one's private or family life.

Case: Buivids (household activity)

CJEU, C-345/17, "Buivids" case

Mr Buivids taped and uploaded to youtube a video of police officers at a police station.

From the slides:

The Latvian DPA ordered to remove the video because he had infringed data protection law. He ^{درخواست تجدید نظر کرد} appealed up to the Latvian Supreme Court which referred the following core question to the CJEU: does data protection law apply in this case? Was it household activity or not? The CJEU stated that Mr Buivids's activity was not household activity since the video was uploaded on the internet. ^{نقض شده است}

Professor Vaciago managed a case relating to YouTube that had the same problem, because ^{انتشار، پخش شدن} dissemination in general is not protected by the household exception. However, if the content is published on your personal Instagram, usually the household exception holds.

Recently, a man installed a GPS on his bike and left the bike unlocked in the streets of Milan. The bike was stolen. Then, he published a video on YouTube about this experience where he claimed to identify the thief, but the person he identified was ^{بی گناه} innocent. In this case, not only the YouTuber is liable but also YouTube itself: why? Because YouTube earned money from the content, which was monetized. The YouTuber cannot ask for the household exception for the same reason: he is making money out of it.

6.2 Four pillars of the GDPR

- **Record of processing activities** → Each controller should maintain a record of processing activities under its responsibility
 - Each record should specify the type of processing, the safety measures...
- **Data processors** → The controller is responsible in choosing a processor that provides sufficient guarantees to implement appropriate technical and organizational measures.
 - If you choose a cheap provider that results in lost / disseminated data, you will be liable. If you prove that the choice of the provider was appropriate, then you will not be liable.
 - The data processor acts on behalf of the data controller.
- **DPIA (Data Protection Impact Assessment)** → Where a type of processing is likely to result in a high risk for natural persons, an assessment of the risks must be made.

- **Data Breach** → In the case of a Data Breach, the controller shall, where feasible, not later than 72 hours after having become aware of it, notify the personal data breach ^{رخنه} to the ^{نیصلاخ، شایسته} competent supervisory authority.
 - A Data Breach is not an IT incident. A Data Breach involves personal data, an IT incident does not.

These are not important for the exam, but are important for our professional life.

6.3 Personal data processing activities

Consent is *not* the only legal basis for data processing. Legal grounds for consent to data processing and monetization is defined by article 7 of the GDPR:

The controller shall be able to demonstrate that the data subject has consented to the processing of his or her personal data.

Written declaration: the request for consent shall ^{باید باشد} be presented in a ^{شیوه} manner which is clearly distinguishable from the other matters, in an ^{قابل فهم} intelligible and easily accessible form, using clear and plain language.

Consent should not be regarded as freely given if the data subject has no genuine or free ^{اصل} choice or is unable to refuse or withdraw consent *without detriment* (Recital 42).

Consent should not provide a valid legal ground for the processing of personal data in a specific case where there is a clear imbalance between the data subject and the controller.

Right to withdraw the given consent at any time, but the withdrawal of consent shall not ^{قانونمندی} affect the lawfulness of processing based on consent before its withdrawal.

Case: Cookie walls

[This case is important for the exam.]

Some online newspapers started to ask for payment in exchange of not installing advertisement cookies before accessing content. Clearly, the choice of using or not using cookies is not “free without detriment” (Art. 7 GDPR seen above). Crucially, a “cookie wall” (no alternative to getting cookies) is already forbidden by the EDPB. ^{بسیار مهم است}

The decision of the Austrian and French authorities is that this kind of cookie wall (where payment is an alternative to getting cookies) is legitimate if the cost is moderate, so as to keep the freedom of the user to opt-out. The decision of the Italian authority is awaited.

6.4 Child consent

Art. 8 of GDPR summarized: Child’s consent

16 years old, but Member States may provide by law for a lower age for those purposes provided that such lower age is not below 13 years. Reasonable efforts to verify by data controllers.

Notice that the request of “reasonable efforts” is another instance of the accountability principle.

6.5 Legitimate interest منافع مشروع

From the slides, Art 6(1) lett. f) GDPR:

Legitimate interests pursued by the controller or by a third party, except where such interests are overridden by the interests or fundamental rights and freedoms of the data subject which require protection of personal data, in particular where the data subject is a child (Article 6.1.f). Legitimate interest is not applicable to processing carried out by public authorities in the performance of their tasks.

Also from the slides:

Balancing test:

- Assessing the legitimate interest of the controller (lawful, sufficiently clear and articulated, real and present)
- Impact on the data subject (nature of the data, methods of data processing, reasonable expectations of the data subject, the status of data subject/controller)
- Additional safeguards to prevent any undue impact on the data subjects

Case: Claudia's pizza (legitimate interest)

Claudia ordered a pizza on a website, entering her address and billing information. Days later, she receives promotional content for products of the same pizza chain. There was an optional opt-out on the website, but she did not use it. Is this legitimate interest?

A brief analysis, from the slides:

The pizza chain has a legitimate, but not particularly compelling, interest in attempting to sell more of its products to its customers. On the other hand, there does not appear to be any significant intrusion into Claudia's privacy, or any other undue impact on her interests and rights. The data and the context are relatively innocent (consumption of pizza). The pizza chain established some safeguards: only relatively limited information is used (contact details) and the coupons are sent by traditional mail. In addition, an easy-to-use opportunity is provided to opt-out of marketing on the website.

On balance, and considering also the safeguards and measures in place the interests and rights of the data subject do not appear to override the legitimate interests of the pizza chain to carry out this minimal amount of data processing.

The optional opt-out is not a basis for consent (as would be an optional opt-in), however it constitutes an additional safeguard against an undue impact on the data subject.

Case: Video surveillance (legitimate interest)

Legitimate interest is widely applicable in the case of video surveillance. As seen earlier, recording people in public spaces amounts to processing of personal data; a legitimate basis for this processing can be found if the location is a typical crime scene, an establishment selling or storing precious goods (banks, jewelry stores...), etc.

However, the data controller still needs to take into account the effect of such processing on the data subject's rights and freedoms (*balancing of interests*). For example, if the pizza chain was sending four emails a day, this could be considered beyond the application of the legitimate interest, as the interest of Claudia not to receive spam would not be balanced by any interest of the pizza chain.

7 20/03

GDPR: data protection by design / default, standards, certification.

7.1 Individual user's point of view and rights

The user has the following six important rights:

Right to access	Right to rectification اصلاح	Right to erasure حق پاک کردن
Right to restriction of processing	Right to data portability	Right to object to the processing حق اعتراض به پردازش

The following are some comments on some of these rights: the user should be able to ask for the rectification of his/her own information, since an inaccurate personal information could be damaging for the individual; the restriction of processing is the right of the user to limit the availability of the data to the data controller without stopping the processing entirely; as for portability, the user should have the right to change his/her own service provider, therefore a user should be able to extract his/her data from a given service in a transferrable format.

Case: Österreichische Post (right of access)

CJEU C-154/21

A data subject requested the Austrian postal service for access to his personal data and for the necessary information to identify the third parties to whom his data had been disclosed. The Österreichische Post gave a generic response and did not disclose the identity of the third parties. فاش شده بود اشخاص ثالث

The court declared that the data subject's right of access to the personal data entails an obligation on the controller to provide the data subject with the actual identity of those recipients, unless: مستلزم

1. it is impossible to identify the recipients, or
2. the controller demonstrates that the data subject's requests for access are manifestly unfounded or excessive,

in which case the controller may indicate to the data subject only the categories of the recipients in question.

In particular, there are some third parties that receive the data who do not have an economic interest to process the data, because they are data processors and not controllers. The data processors do not have to be disclosed in advance to the data subject, even though in general the data subject has always the right to know who is processing his or her data.

Case: BPER Banca (right to be forgotten)

Italian DPA case 305/2022

From the slides:

On January 12, 2019, a data subject emailed BPER Banca (data controller) requesting to erase his professional profile. Few days later, the bank asked for the data subject's ID to enable his identification. The data subject immediately sent the requested information. However, the bank took no further action.

The data subject submitted reminders both in April and in May 2019.

Only on June 17, 2019, the bank confirmed the erasure.

The Italian DPA concluded that the controller's late and inadequate response to the request for erasure submitted by the data subject was unlawful and issued a 10k€ fine.

The right to erasure must result in erasure within 30 days of the request. Any delay could result in fines.

Case: Caffeina Media, Google Analytics (data transfers to the US)

[This case is important for the exam.]

This case was lodged as an example of a violation that is widespread and difficult to avoid, caused by the existence of the power of the President of the United States to request access to data controlled by American companies. The lack of an agreement between the EU and the US on how to preserve the fundamental rights of the European citizens regarding data means that transferring data to a controller based in the US can easily result in a violation of the GDPR.

A complaint was issued that the company (Caffeina Media) was sending data to Google LLC, in the US, without the safeguards required by GDPR Chapter V.

From the slides:

The company was using on its websites Google Analytics, a tool allowing statistical analysis to optimize their services and monitor their marketing campaigns. While the data was officially transferred to Google Ireland, the Italian Authority held that the use of Google Analytics entailed the transfer of the personal data to the parent company Google LLC, based in the United States.

In the absence of an adequacy decision with the US, such transfer is only possible if appropriate safeguards are adopted, which was not the case, according to the Authority.

The company was not fined immediately, but the decision has far-reaching consequences in the world of privacy compliance, causing all companies to re-evaluate their analytics tools and the data transfers of big tech companies to the US, even when there is a screen company in the EU.

Read something about Max Schrems, Professor Vaciago *looooves* him. From Wikipedia:

Maximilian Schrems (born 1987) is an Austrian activist, lawyer, and author who became known for campaigns against Facebook for its privacy violations, including violations of European privacy laws and the alleged transfer of personal data to the US National Security Agency (NSA) as part of the NSA's PRISM program. Schrems is the founder of NOYB – European Center for Digital Rights.

Case: Immuni (pseudonymized data)

[This case is important for the exam and Professor Vaciago was personally involved in it.]

The Immuni App was a system to track epidemiology information to prevent the spread of epidemics like COVID-19. Sadly, this system did not work very well. However, it was carefully designed in terms of privacy. They were specifically designed to avoid centralized collection of location data. It should be observed that our location data is available to the President of the United States any time we use Google Maps, but we did not accept to release it to the European governments for the purpose of preventing a pandemic.

The contact tracing app was not mandatory to download and many people did not download it. However, the main reason why this app was a failure was the lack of consent to the centralized collection of data. ^{اجباری} It is an important question whether the compulsory download of the app and the centralized collection of data can be considered legitimate in the balance of interest (clearly, public health is on one of the “plates” of the “balance”).

Data collected by the Immuni tracing app occurred in two forms:

1. Anonymized: does not related to a directly or indirectly identified or identifiable natural person.
2. Pseudonymized: data can be attributed to a natural person through the use of additional information.

This distinction is the most important concept to remember from the Immuni case.

7.2 Sanctions

Sanctions issued under GDPR are up to 20M€ or up to 4% of the company’s global revenue. Some sanctions have half the value. Note that, since the thresholds are joined in a logical “or”, the 4% threshold is not intended to decrease the maximum amount for some companies but to increase it for some high-revenue companies. The fines can vary a lot from case to case, there is still a lot of arbitrariness.

Case: OneDirect (inability to exercise rights)

Resulting sanction: 30k€

Case: Vodafone (aggressive telemarketing)

Resulting sanction: ~12M€

Case: WindTre (overly aggressive marketing)

Resulting sanction: 17M€

8 21/03

GDPR

Data breach

External governance (SA, EDPB, courts)

Data transfers

Sanctions

8.1 Part I

8.1.1 GDPR Compliance

Four important rules (important for the exam, too, in the context of accountability):

1. Analyze what you collect and where you store it → processing activity register.
2. Check if the data is not stored at times when it is no longer relevant; if so, remove the data → Data Retention and Disposal Policy.
3. Inform your clients how they can modify or delete their data → privacy policy webpage
4. Monitor who has access to the personal data.

8.1.2 Task distribution

There are several important players:

- **Data subject:** an individual person located in the EU.
- **Data controller:** ^{یک شخص حقوقی} a legal entity processing personal data (except when the household exception applies).
 - The data controller determines the purposes for which and the means by which personal data is processed.
 - It is possible to be in a situation known as joint-controllership. From the slides:

Two or more controllers jointly determine the purposes and means of processing.

[There must be a] formal agreement between joint-controllers.

[They must] determine respective responsibilities and obligations in particular as regards the exercising of the rights of the data subject and their duties to provide the information (so-called privacy policy) to the data subjects.

The data subjects may exercise their rights in respect of and against each of the controllers.

- **Data protection officer:** ^{نظارت کردن} a person appointed by the data controller, responsible for overseeing data protection practices.
- **Data processor:** an institution that processes the data on behalf of the controller.
 - From the slides:

The decision-making power over data processing is the criterion for distinguishing between controller/processor.

Different level of control over data processing and different accountability/liability.

Quality of data processor: the processor must provide sufficient guarantees to implement appropriate technical and organizational measures in such a manner that processing will meet the requirements of the GDPR (Article 28.1).

- There must be a contractual ^{قراردادی} relationship between the controller and the processor.
- It is very frequent that data breaches ^{نقض ها} happen on the side of the data processor. Therefore, it is necessary to choose a data processing supplier that maintains sufficient safety standards for the controller's application.
- It is possible to have a deeper supply chain of data processing, which causes the existence of the so-called "sub-processor". From the slides:

The processor can engage another processor with prior specific or general written authorization of the controller (Article 28.2).

The same obligations as set out in the contract or other legal act between the controller and the processor are imposed on the sub-processor.

[The sub-processor] guarantees to implement appropriate technical and organizational ^{معیاری} measures.

The initial processor remains fully liable to the controller for the performance of the sub-processor's obligations (Article 28.4).

- Data protection authority: a country-level public institution monitoring the implementation of the regulation in its country.

8.1.3 Data protection officer

Art. 37 GDPR mandates the designation of the data protection officer by the data controller, who can be external or internal. The DPO is mandatory for public authorities or bodies, data controllers or processors whose core activities consist of processing operations which require *regular and systematic monitoring of data subjects on a large scale*, data controllers or processors whose core activities consist of *processing on a large scale of special categories of data* or personal data relating to criminal convictions and offenses (judiciary data).

The DPO should ideally be an expert in law and information technology, which is often not the case. Finally, the DPO should be in a place of no conflict of interest with regards to the company he/she works for. This is achieved by forbidding the company from instructing the DPO, from issuing penalties to the DPO based on his/her performance, by mandating there not be any other source of conflict of interest in carrying out the DPO's tasks, and establishing that DPOs are not personally responsible for non-compliance with data protection requirements.

Case: GLOVO Spain (data protection officer)

The Spanish DPA imposed a fine of 25k€ on Glovo for the non-compliance with its duty to appoint a DPO. Glovo has an obligation to appoint a DPO because his activity consists of processing on a large scale of special categories of data, in this case food preferences ^{اولویت ها}. Food preferences are special categories of data because they are strictly related to health data and religious data.

Case: Giesege (lack of data processing agreement)

From the slides:

Giesege Industria Mobili SpA was a data controller and it was in a contractual relationship with a processor (Verizon) who provided geolocation devices. The controller installed these devices to track vehicles delivering goods on its behalf. These vehicles were not directly owned by the controller, but rather by a third company, to which the controller outsourced certain services. The data subject was a driver employed by this third company, and he had no direct contractual relationship with the controller.

Since no controller-processor agreement existed between Giesege and Verizon, the Italian DPA fined Giesege 50k€.

Case: ISWEB (lack of authorization to engage a sub-processor)

ISWEB SpA (data processor) developed a web application for a group of hospitals to collect and manage employees' whistle-blowing reports. ISWEB contracted the company Seeweb for hosting the whistle-blowing application. However,

ISWEB did not ask the prior written authorization from the controller for engaging a sub-data processor, and did not formalize its processor-sub-processor relationship with Seeweb through a contract or other legal act.

ISWEB claimed that it was not processing personal data as the whistle-blowers' reports were encrypted with a key exclusively available to the hospitals. The Italian DPA did not agree with the claims and fined the processor 40k€ for violating Article 28(2) GDPR.

Case: Jehovah todistajat (joint-controllership)

The Jehovah's Witness collect personal data during their door-to-door activities, including names and addresses of persons unknown to them without their knowledge or consent. Even though the processing is carried out by the members, the Court held that: *دادگاه تصمیم گرفت که:*

A religious community is a controller, jointly with its members who engage in preaching, for the processing of personal data carried out by the latter in the context of door-to-door preaching organized, coordinated and encouraged by the community, without it being necessary that the community has access to those data, or to establish that that community has given its members written guidelines or instructions in relation to the data processing.

Moreover, the Jehovah's Witnesses were forbidden from processing personal data unless the legal requirements for processing were satisfied.

8.1.4 Accountability of the controller

The principle of accountability results in the need to define a strategy to follow the four pillars of GDPR compliance listed above.

Case: Enel (accountability)

Enel Energia is an important Italian energy provider. The Italian DPA received hundreds of reports of unwanted promotional phone calls, made by Enel's marketing partners. The promotional campaign was described as ^{تجاوز}invasive, ^{خشونت آمیز}aggressive and a ^{مداوم}persistent and ^{بیخالت}disturbing interference in the citizens' privacy.

The Authority established:

^{تخلف، نقص}Violation of Article 5(2) GDPR and Article 25(1) GDPR, for *not having taken effective action against undue promotional contacts made in its name* by exercising its duties of accountability and privacy by design (through elements of prevention, functionality, security, transparency of treatment and centrality of the person concerned).

Violation of Article 5(2) GDPR, for *failing to provide evidence of compliance with data protection legislation* in the case of unsolicited promotional communications by a business partner.

Violation of Article 5(2) and Article 24 GDPR, for *failing to control the activities of its business partners*, including through appropriate technical and organizational measures.

Remark: in the field of data protection, it is not possible to specify which rules must be respected absolutely, so accountability forces a case-by-case approach relying on the data controllers and processors. The point is: even if a mistake is made, if it happened in good faith and it is possible to provide evidence of compliance, there will not be a sanction (as defined in previous lectures, this is the principle of strict liability with possible derogation).

8.2 Part II, III

8.2.1 Security of data in the context of accountability (Art. 32 GDPR)

The important part to remember on cybersecurity is the content of Article 32 (from the slides):

Taking into account the state of the art, the costs of implementation and the nature, scope, context and purposes of processing as well as the risk of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, including inter alia as appropriate.

Furthermore:

The controller/processor must ensure that any natural person acting under their authority does not process personal data except on instructions from the controller, unless required by law (Article 32.4).

So, the security obligations are shared between the controller and the processor. The technical and organizational measures to be taken should be proportional to the risks to the individual rights and freedoms of the data subjects, taking into account the nature, scope context and purposes of processing, the state of the art of the technology and the costs of implementation, and any other relevant factor (an open-ended list).

Some examples of technical and security measures or tools are: pseudonymization, encryption, testing tools, any measure to ensure availability, business continuity and resilience (eg backups).

In practice, one could read the ENISA report on technical organizational security measures. ENISA is a European agency that develops standards in Cybersecurity. The pillars of data security in terms of technical measures, according to ENISA, are:

- Spread the Cybersecurity culture.
- Issue training courses to engineers.
- Evaluate the relations with third parties who can access the company's data.
- Develop a formal plan to face a data breach.
- Develop safe authentication (avoid reusing passwords, and prefer passphrases).
- Keep the software on the devices safe (malware detection, encryption, etc.)
- Keep the corporate network safe (implement a firewall and constantly review technologies like VPNs).
- Keep the physical devices and buildings safe (key-loggers may be physical devices, not only software, sometimes laptop sessions are not locked).
- Make safe, regular, separate and immediately available backups.
- Assess the security of any cloud service in use.
- Websites security, if applicable.
- Search and share information with the security community and similar businesses.

The pillars in terms of organizational measures are:

- Organizational model (definition of key players, such as IT administrators, DPO...).
- Privacy policies.
- Policies on data retention, data breaches, risk and privacy assessments.
- *Privacy by design*.
- Ask and collect consents.
- Documentation: record of processing activities and data processing agreement.

The takeaway on security is: follow good standards.

Case: Rousseau (security)

An investigation on the Rousseau remote voting system (special categories of data) revealed that the administrator credentials were shared among employees of the data center, rendering it impossible to attribute administrative actions on the system to any one specific person.

The violation of Rousseau was non-adoption of security measures as required by Article 32 GDPR. The penalty was 50k€.

8.2.1.1 Risk assessment

The strategy towards a secure approach to data consists of three ingredients:

- ❖ Preliminary analysis ^{مقدماتی} → analyze the risks.
- ❖ Data strategy and data management → detail how the data will / should be processed.
- ❖ Data minimization and by-design approach → restrict the processing only to the data strictly necessary for the purpose at hand and protect the data with appropriate measures (remember the concept of preventive paradigm, as opposed to prescriptive paradigm).
 - The “privacy by default” principle is to process only the necessary personal data: a classical example is opt-in vs opt-out.

^{انتخاب کردن در مقابل انصراف}

Furthermore, the steps to be taken are:

- ❖ General assessment according to Articles 24 and 32 and develop a by design / default approach according to Article 25.
 - This must assess security risks and their impacts on the individual rights and freedoms.
 - This should also discuss the state of the art and the costs of implementation of each countermeasure.
 - As part of the general assessment, appropriate technical and organizational measures should be detailed.
 - Circular approach (assessment → measures → tests → assessment → ...)
- ❖ Make a formal assessment according to Article 35 (is there a high risk for the data subjects?)
- ❖ Consultation with the data protection authority according to Article 36.
- ❖ Comply and enforce (Article 83.4.a).

8.2.1.2 Data protection impact assessment

^{بیش بینی شده است}

The DPIA is a document which describes the envisaged processing operations and the purposes of the processing, explains why the processing is necessary (proportional) to the purposes, assesses the risks to the rights and freedoms of data subjects, and details the measures to address the risks (safeguards) and how they result in eventual compliance with the GDPR. The DPIA is necessary when there is a high risk in terms of impact on the individual rights and freedoms of the data subjects (Article 35 GDPR).

The DPIA does not have to be published, but a partial publication (of the conclusions) is recommended by the EDPB. The same DPIA can be used for multiple processing operations, if they are sufficiently similar. It can also be used for multiple uses of the same technology (under similar constraints). Sometimes, it could be necessary to make an additional DPIA for the specific implementation of a technology, even if a DPIA already exists for that technology.

Furthermore, according to Article 36 GDPR, prior consultation with the DPA is necessary in the case of high residual risk, and the possible outcomes can be the implementation of the DPIA or the interruption of the data processing.

8.2.2 Data breach

From the slides:

Article 4 GDPR defines data breach as a “personal data breach” which is a security breach that accidentally or unlawfully results in the destruction, loss, alteration, unauthorized disclosure of, or access to, personal data that has been transmitted, stored, or otherwise processed.

If the breach does not impact personal data, it is categorized as an IT incident.

Classification of data breaches:

- **Confidentiality breach:** there is an accidental or abusive access to personal data.
- **Availability breach:** there is an accidental or unauthorized loss or destruction of personal data.
- **Integrity breach:** there is an accidental or unauthorized alteration of personal data.

Some examples:

- Loss of a non-encrypted device: this could result in a confidentiality breach.
- A device is infected by ransomware: a ransomware causes, at least, a temporary loss of availability (availability breach).
- The loss of availability is caused also by accidental transmission of the data to a third party (which also causes a confidentiality breach).

In the case of a breach, the company should put in place a remediation plan to show that it has “learned the lesson”. This means that all appropriate measures are taken to mitigate the current incident and avoid the repetition of the incident.

8.2.2.1 Obligations in the case of a data breach

The controller is obligated to notify the DPA without undue delay, ie within 72 hours from the time when the breach was known to the controller or processor. The controller is also required to notify the data subjects when the data breach is likely to impact their individual rights and freedoms.

The controller has, in general, an interest to avoid or at least delay the notification. From the point of view of public security and the individuals, the earlier the breach is known, the better. The 72-hour threshold is a compromise in this regard.

The notice must contain:

- Nature of the personal data breach (category, number of data subjects, records).
- Contact details of the DPO.
- Describe the likely consequences of the breach.
- Describe the measures taken or to be taken.

The risks to the rights and freedoms of individuals due to a data breach depend on:

- The type of breach (confidentiality, availability, integrity).

- The nature, number and degree of sensitivity of the breached data.
- Ease of identification.
- Severity of the consequences for the data subjects.
- Number of data subjects exposed.
- Characteristics of the data controller (hospital vs airline vs hotel...).

فاش کردن

Sometimes it is not necessary to notify the data subjects. In general, the DPA will not disclose the breach. This is the case when (from the slides):

The data controller has implemented appropriate technical and organizational measures.

The controller has subsequently taken measures to prevent the occurrence of high risks to the rights and freedoms of data subjects.

Such communication would require disproportionate efforts, so it may be replaced by a public communication.

The first and second points are very hard to prove. As a result, the general criterion is assessing the risk towards the individual rights and freedoms of the data subjects.

The results of a data breach are generally disastrous for a company.

The notification to the DPA should come from the data controller. The data processor is obligated to notify the data controller as soon as it becomes aware of the incident *without undue delay*.

8.2.2.2 Data breach register

According to Article 33.5 GDPR (from the slides):

The controller should document any data breach, including the circumstances surrounding it, its consequences and the measures taken to remedy it. Such documentation shall enable the supervisory authority to verify compliance with this Article.

There are two tools to use:

- The incident log, a concise but timely updated log of IT incidents and data breaches.
- Internal reports, which must be created with standard and easily accessible templates. The templates and the reports should be updated as action plans evolve, risk assessments are made and decisions are taken within the organization.

9 28/03

Mantelero is back.

[Today we will review some cases assuming a good understanding of the GDPR.]

9.1 Data protection impact assessment (example cases)

In a product, we want to first assess the risks that are inherent in the product (preliminary analysis). Then, we will assess the significant risks more formally and systematically, *and design mitigation strategies*, through a DPIA.

Remember: the DPIA is required (Article 35(1) GDPR) whenever there is a high risk affecting the individual rights and freedoms of the data subjects.

There are three cases in which the legislator presumes a high risk, detailed in Article 35(3).

There is another case in which an assessment is required, and it is the presence of data processing security risks (protection from IT incidents and data breaches). This is another type of assessment, separate from the data protection impact assessment. This is detailed in Art. 32 GDPR.

Estimating the impact of data processing in terms of the individual rights and freedoms is very complex, much more than assessing the security of data processing (which is a technical issue). For example, the impact of LLMs is much more difficult to assess in terms of societal impact and impact on the fundamental rights, while protecting the system from unauthorized use is a challenging, but strictly technical task with clear goals. The risk assessment should not be done at the end of the product design, but it is a criteria that should impact the design itself (data protection by-design).

Case: Smart factory (example of data protection impact assessment)

An exoskeleton is a “wearable robot”, which should enhance the capabilities of the operator or relieve his / her disabilities. The exoskeleton should be designed in order to fit the body of the operator.

How do we design the exoskeleton? It is necessary to measure the operator body size. With which means? For example, we could use a traditional measuring tape; we could use photographs; we cannot use the uniform size, it is not precise; we could ask employees to self report their measures; we could use a 3D body scanner...

In the real case, they used a 3D body scanner. Of course, that amounts to processing of special categories of data by the employer (health data, biometric data). According to the GDPR, this is not strictly biometric data as it is not used for identification, but it *can* be used for such purpose, so it is quasi-biometric.

According to Article 35 GDPR, we need to balance the purposes and the processing. Do the purposes justify the processing? For the exoskeleton design, it is not strictly necessary to use a 3D body scanner, even though this might be more efficient. Probably, taking old-fashioned measurements is more privacy preserving and can be sufficient for the purpose of creating the exoskeleton.

Now, let's complicate the case: we need to create an exoskeleton specifically for a disabled employee. This case is different because we *need* to know specific information on the disability to build the exoskeleton. In this case, processing of special categories of data is unavoidable. The use of the body scan is acceptable, but not altogether: we need to have precise measurements (to fit the disabled body) but not of all the body. The fact that we cannot avoid processing special categories of data does not justify all forms of such processing, the data processing should *still* be minimized.

What about the body scan after the exoskeleton has been created? It could be deleted, even if the machine requires maintenance, replacement, etc. it should not be necessary to keep the body scan. However, there may be cases in which the disability could change over time. In this case, it may be less invasive to keep the first scan and perform updates on that one rather than performing periodical scans.

Case: Self-adapting workstation (example of data protection impact assessment)

A workstation adapts automatically to the parameters found by the body scanning performed on the employees, to result more ergonomic. Imagine one of these sensors collect body temperature. Is this personal data? If the company is able to associate the temperature to a specific person (ie, looking at the working shifts), this is at best pseudonymized data, if this information (the association temperature-shift and the association shift-worker) can be effectively be kept separate. In any case, it is personal data. It is *not* personal data only in the case that there is absolutely no way to relate a temperature measurement with a given employee (eg, heavily shared workspace and no planned shifts).

How long should the data be kept? It could be discarded at the end of the shift, or at the end of the contractual relationship between the employee and the company. In this case, since the only purpose is adapting the workstation as it is being used, the processing should be limited to the shift. Even better, it could be limited to a “typical time scale” (eg, in the case of body temperature, it could be updated every 10 minutes and immediately discarded). However, even during the shift, it is better if the information on the employee who is using the workstation and his / her body scan are kept separate (pseudonymization). An exception that would be a good cause to store the data for long is, for example, when the company has a reason to suspect that the employees may develop work-related health conditions and the body monitoring gives the company the power to warn the employees of the appearance of symptoms, thus protecting his / her welfare.

9.2 Biometric data

The smart factory and self-adapting workstation cases lead us to the definition of biometric data, which is, as already seen, a special data category. This definition is contained in Article 4(14) GDPR. From the slides:

[...] personal data resulting from specific technical processing relating to the physical, physiological or behavioral characteristics of a natural person, which allow or confirm the unique identification of that natural person, such as facial images or dactyloscopic data.

However, according to Recital 51:

The processing of photographs should not systematically be considered to be processing of special categories of data as they are covered by the definition of biometric data only when processed through a specific technical means allowing the unique identification or authentication of a natural person.

There are also some distinctions to be made with regard to biometric data: some parts of the body are much more sensitive than others. Facial data (when it counts as biometric data as seen above) is

more public and easily accessible, so it should be much more protected, then, say, data about fingerprints [Ed. which is still very sensitive, don't get me wrong].

The storage of fingerprints can also be subject to processing minimization. Rather than collecting the fingerprint image in the company's server, it is much better to place the fingerprints directly inside the sensors that will be using them. Even better, employees can use cards that store their fingerprint, and the card is used to authenticate the employee's fingerprint.

9.3 Large-scale project management I

When managing a large scale project from the data protection point of view, there are several factors to consider that are specific to the large size. First, one should note that a large scale project collects *a lot* of data. It is easy to overestimate the effectiveness of any anonymization procedure. The data may not be really anonymous if it is possible to undo the anonymization with some algorithmic procedure.

A useful tool to plan a data strategy is the Data Management Plan. It is an important tool, a plan in which all the processing operations and those that are involved are mapped. This is important in terms of monitoring the data flows (which in turn is helpful for the anonymization process, if necessary) and the actors that may be using the data (which is helpful to define the purposes of the processing).

These projects are usually within the boundaries of Article 35, and therefore require a DPIA. The DPIA usually focuses on the project at hand, but the DPIA of large scale projects should take into account the cumulative impact of the project, ie the impact that the project may have on other social processes. For large scale projects that consist of multiple applications, the synergy between the different applications must especially be taken into account. Also, it is necessary to carry out a level of harmonization to comply with all legal requirements of all contexts that the project encompasses.

10 03/04

10.1 Italian DPA and OpenAI in Italy

[Brief discussion of the recent decision of the Italian DPA to interrupt some operations of OpenAI in Italy.]

Background cases: TikTok and lack of necessary limitations for minors; Clearview AI's facial recognition and lack of consent, based on the false idea that the availability of material online means an unlimited possibility to use it, which is completely false.

The intention of the DPA is not to stop innovation, it is a matter of what kind of ethics of innovation we want. We *could* base innovation on the exploitation of individual's rights and freedoms, a high impact on the environment, etc. In Europe, due to data protection laws, we cannot have companies from other countries (or even our own countries) collecting our citizen's data and exploiting it to improve their products, without a proper legal basis. In many cases, the problems of the IT sector originate from the old thinking frame "move fast and break things", which often translates to "do things without thinking about the consequences".

In particular, in the case of ChatGPT, the Italian DPA urgently requested the interruption of OpenAI's operations in Italy, but this order is not a sentence, it is an emergency evaluation. The first issue of the DPA with OpenAI was the illegal collection of data to create the service: the datasets used by OpenAI were made without regard to the legal bases for processing of the content, and whether it amounted to processing of personal data. This is different from what search engines do, the crawlers can read the `robots.txt` file which gives control to the owner of the website. Secondly, the issue with OpenAI is that it cannot be considered a research project, since their products are commercially available and their purpose is to raise a profit. Third, there is no way to rectify a person's data after it has been used as part of a training set. Finally, there is no age verification on the tool (just like the TikTok case).

The decision of the DPA is that the processing of personal data must be interrupted, it is not directly a block. Since in this case the interruption of processing of personal data implies the interruption of the availability of the product, it seems like a block on OpenAI's services.

10.2 Large scale project management II

Data protection is not the only critical part of large scale projects, but we must evaluate the social impact too. This is why many large scale projects usually create ethic boards to perform a general evaluation of all ethical factors.

Cooperation is also very important, where the system is composed of several parts. If a system service is exporting data and the other is not, we must make sure that in the specific case the data exporting is legal. Usually, it's better to aggregate the system services that perform a similar task subject to similar rules.

Furthermore, it is important to consider the cumulative aspects that are the result of the interaction of different streams of data (eg, bike sharing data + political orientation data collected from different platforms). So the DPIA should include the cumulative processing operations and the sub-systems that they put together.

Then, we need to consider the role of participation. Through the active engagement of the citizens in the design of a large scale problem, the bias of the data science / engineers / designers are diluted.

Case: Piedmont's smart public transport system (example of large scale project)

The Piedmont's region decided to monitor passenger flows with a high level of granularity. This led to the introduction of the BIP integrated ticket system. In terms of data protection, there are two main streams of data:

- Contractual information → identity of passengers, type of their tickets and some demographic information about them.
- Mobility information → which kind of line has been used, from which stop, to which stop, etc.

The contractual information should always be accessible to manage contractual issues. However, for the purpose of optimizing the transportation system, it is not necessary to store personal data coming from the "mobility information" stream; ie, the data can be anonymized.

Background: in the London case, the city of London decided to share the bike sharing information as open data. This led to the possibility of de-anonymizing the data and gathering lots of information about where and when some people lived and travelled.

In the case of the BIP integrated ticket, the data is progressively anonymized. The first step is to keep separate the contractual information dataset and the mobility information dataset. However, at this point the data is only pseudonymized, because it is sufficient to join the two databases. There are some cases where the join is useful, for example for fraud detection or stolen cards. However, these cases usually arise in a short time, so the possibility to join the two datasets can be removed after 72 hours. It is still possible to know that two trips have been taken with the same card, and this could lead to de-anonymization. After 60 days, all the information that indicates that two trips were done by the same person is broken. At this point (60 days) the data is fully anonymized.

10.3 Regulatory competition

There are many other countries that implement data protection laws. There is a competition to be the global rule setter. Some systems are “authoritarian”, some are strongly market oriented, some are more data-subject-right-preserving like the GDPR.

So far, all attempts by the UN to create an international data protection agreement have failed. Besides, there is a clear economic interest in being the “rule-setters” in data protection regulation and AI regulation, which makes it harder for different parties to agree, as that would almost inevitably result in a competitive advantage for some and a disadvantage for others.

11 04/04

11.1 Regulating AI I, ethics of AI

There is a proposal in Brussels to take initiative on AI, through an immediately-binding AI Act. However, this is just a proposal and it has been the object of a very long debate for several years. We cannot base our study on this Act as it has not yet passed parliamentary procedure, but we can focus on its key elements.

We realized that data protection law is not sufficient / appropriate to regulate AI. Data protection law has its roots in the 1990s, and it is obviously not ideal for the newest technological landscape. Modern data protection has its center on the need to evaluate the risks of data processing, in order to adapt to the fast-changing scenario of data processing and shift responsibility of the technical evaluation on the creators of a technology (accountability, principle-based regulation, soft law).

However, some aspects of the GDPR are already outdated, at least in their intent: for example, it is necessary to specify the purpose of processing at the time of data collection, so that everyone has a clear understanding of the consequences of such processing. In the case of AI it is impossible to know the “final” purposes of processing in advance. Many results obtained from AI algorithms are unexpected and it is impossible to predict the use of a training set (and the models trained on it) at the time of data collection. Furthermore, the data subjects cannot be expected to be aware of the consequences of the data processing in the AI context (even the engineers are not completely aware). As an example, the credit score in the US has been known to be calculated taking into account the TV shows that people watched. Sometimes, AI tools use forms of deep learning that are

difficult to inspect. The combination of these different elements makes it very difficult to make the data subjects aware of the consequences of the data processing.

Another distinction of traditional data protection regulation from AI regulation is the focus on the “identified and identifiable natural persons”. In AI, the consequences of the use of data arise more from people’s belonging to large categories than from the possibility of identifying them by singling them out, rendering the traditional data protection regulation, once again, outdated.

The first reaction of the legal community to AI was to shift the focus on ethics. Data protection issues are just a part of the issues of AI, which in general relate to ethics. The issues are, for example, discrimination, false information, and many others. In other areas of ethics of technology, ethics is a relationship between humans and a piece of technology. In data ethics, the relationship is between humans and data, which in turn represent humans, giving rise to a sort of circular relationship. In the ethics of AI, a huge problem is how to translate any potential problem in liability (how to assign responsibility).

It is important not to confuse ethics and law; law is a codified product of ethics and other conflicting interests (and conflicting ethics), and of course they do not always overlap. Another important point is that ethical values are different from the laws, since laws are generally accepted, but in ethics there are many different ethical approaches, at cultural and theoretical level (Kantian, Socratic...). When we select an ethical framework, this is a decision that limits other options. The ethical approach has the problem of creating a cultural-centric approach, where only the ethical values of a given culture are translated into law. Furthermore, it is important to distinguish different ethical contexts (eg military vs medical context: military AI and medical AI can reasonably be expected to follow different ethical codes).

To summarize, the approaches to regulate AI are: data protection, ethics, protection of human rights. The protection of human rights includes data protection (it is a human right, at least in the form of the right to privacy, as we have seen from Article 12 of the Universal Declaration of Human Rights, Art 8 of the European Convention on Human Rights, Art 8 of the Charter of Fundamental Rights of the European Union), but it is not limited to it.

The debate around AI occurs at the academic level (extensive literature) and at the institutional level (simplified version focused on the outcome key values). Companies create their own lists of values and ethic boards that are tasked with their implementation. The problem in this approach is the conflict of interests (the selection of the board members is non-neutral, the resources of the ethic board can be manipulated to regulate the actual impact of the board).

The lack of a legal framework resulted in an effort to aggregate all the different strategies to find what are the common values of the ethics of AI. The limitation of these efforts are due to the fact that they are a mix of unofficial documents, the fact that in many case documents in uncommon languages are not considered, the fact that the approach is based on the frequency of the values. About the last point, the problem is that the cumulative authoritativeness of the sources in which a given value appears is a much more important measure of the impact of a given value than the frequency of the value in the sources.

Furthermore, the choice of values does not immediately solve the problem, as it is still not clear how these values are upheld. Some values are already present in the law (for example, in the GDPR), so they do not need new legislative action.

If this is the state of the art of the debate, what can we say about the role of ethics in AI regulation? What we can say is that ethics and law serve different purposes. There is a lack of full answers in the legal framework, and ethics can contribute these answers. However, the ethical approach cannot replace the law (in this context, you can think “law equals a human-rights based approach”, ethics concerns the circular relationships between people and data, society and technology).

11.2 Regulating AI II, impact on human rights

First, we will discuss the connection between data protection regulation and AI regulation. The data protection approach has been for many years the main framework (and still is) to regulate the use of data. This is proven by the decision of the Italian DPA on OpenAI. However, this also stresses the lack of a regulatory approach appropriate to AI. The big problem with AI is not the processing of personal data, but the overall impact of AI on society. Data protection is a means more than a goal to provide fundamental human rights.

We realized that the task of regulating AI goes much further beyond data protection. A point that was surfaced in the US is the racial discrimination in AI. For example, the Compass case was an attempt to use AI to determine the likelihood that a criminal would commit a crime again. The software systematically discriminated black people [Ed. I want to point out that I was able to write “black people” before the professor said it].

It is important to discuss the context of the use of AI to imagine the fundamental rights that could be impacted, the legal ground of these rights and how to be legally compliant. The data protection framework is not sufficient, but it is a useful starting point to regulate AI. A key principle that is used by data protection is the impact assessment and the by-design approach, which should be used in AI with a broader range. The concept of accountability (that we have seen in data protection) is also important, because it constitutes a motivation for businesses to be compliant with regulations and make a careful impact assessment. In the case of start-ups, for example, it is very hard to rely on an ex-post approach to liability (they have no money to compensate damages), so prevention is much better than cure.

The second important point that we have already seen, is the fact that technology is not neutral, but it can and will shape society. AI systems are now so pervasive that it is very difficult to evaluate, from an individual’s point of view, their impact on his or her life. Furthermore, the problem of AI-driven discrimination is that it is not always possible to determine who is subject to discrimination, and many algorithms emphasize the individual dimension: it means that people are categorized and possibly discriminated based on non-traditional categories, which makes it very hard to make a collective legal action. Finally, often sophisticated and risky AI products are the result of a partnership between the public and private, which increases the power imbalance between them and the individual, and often results in the impossibility to achieve the necessary transparency to evaluate fairness. The only solution is to go to a court and ask for compensation, but this is not ideal, because companies may not be able to pay, and the subjects may not know that they have been harmed.

Clearly, the regulation cannot only focus on risk assessment but also the ex-post assignment of liability (taking into account what was done during the risk assessment phase). The AI Act so far is an ex-ante risk assessment regulation. There are many nuances to the risk-based approach. For example, what is the scope of risk assessment? Should only consider negative outcomes? So far, the

dominant approach in the domain of AI is to evaluate pros and cons of a piece of technology, and “correctly” weight them. However, systematic definition of the impact assessment must still be developed.

The AI Act asks for the development of a Fundamental Rights Impact Assessment on AI applications, but the problem is that, unlike the Data Protection Impact Assessment, there is no established methodology to make such an assessment. The mindset should remain the same:

- Preliminary analysis
- Mitigation
- Evaluation

applied in a circular approach.

Finally, when we discuss about a risk the fundamental assumption is that the risk is known. Since this is not always the case with AI, there is also the precautionary principle. If we know that there is a risk, but we still don’t understand it (the level of risk is uncertain), we must interrupt the use of some applications.

12 13/04 Regulating AI III, risk-based approach

[After a brief update on ChatGPT, not reported here, we go back to studying the AI Act.]

There was a brief discussion on the initiatives around the globe to regulate AI. Moral of the story: nothing significant has been done, but the US is moving ahead.

The goal of the AI Act for now is risk management. For now, there are no principles that aim to direct the development of AI, nor are there any principles for an ex-post assignment of liability. At the moment the structure of the AI Act is only focused on high risk, risk assessment and risk management. Something similar to the “by-design” approach (which would guide the design, ie the development of AI systems) is lacking.

There are only provisions for the high risk cases but few general provisions for all generic cases. In the GDPR the high risk is a threshold, above which there cannot be any data processing in the absence of balancing interests (risk mitigation is mandatory). In the AI Act, there is acceptability for high risk regardless of the balance of interests, as long as the possible mitigation measures are performed. Secondly, the risk assessment in the GDPR is open (self-assessment), while in the AI Act there is a list of high-risk cases that define what is a high-risk application. However, the categories are very broad and it is difficult to evaluate whether an application is in the list. Since the AI Act concerns high-risk applications, the list defines the scope of the Act. There are also some “super”-high-risk applications that not only cannot be merchandised but also cannot be developed. However, the medium- or small-risk applications do not fall within the scope of the Act (for now), and yet they are very pervasive just because of their quantity.

The AI Act is mostly focused on safety and security, and partially on fundamental rights. But the impact of AI on fundamental rights is much harder and urgent to manage. It is simply asked to perform an assessment, without there being a consolidated tradition in evaluating the impact of AI on fundamental rights.

The AI Act contemplates two cases: AI as a part of an already regulated instrument (planes, self-driving cars); AI as a standalone product. For the first cases, there are some regulatory tools available, which are maintained and integrated. For the standalone cases, there is no background at all on regulation.

The AI Act high-risk applications are considered high-risk for two reasons:

- either they are parts of a high-risk application according to existing safety regulations
- or they are considered a standalone AI application that is a suspected high risk

the AI Act requires mitigation for high risk applications, but does not prohibit them. When case law will be available, the notion of acceptability for high-risk applications will be clearer. The mitigation strategies can be removing or reducing the risks, and provide information to the customers. The risk model of the AI Act mixes the impact on human rights and the risk in terms of cybersecurity. This is not ideal and could lead to confusion, since these aspects are so different.

In the certification of AI systems in the AI Act, there are elements of self-assessment (security assessment and human rights impact assessment), elements of standardization, elements of third party assessment. The AI Act does not include the perspective on ethics and the direction that AI should take and how it should be useful in our societies.

The idea of a participatory approach to the assessment of AI is still not a part of the AI Act.

13 17/04

Today we conclude the part on data ethics and law. We will finish the part on AI and do an exam-like exercise.

13.1 Regulating AI IV, the ethical approach in practice

AI Act's risk assessment is focused not only on security but also on fundamental rights. There is some background in this because the DPIA focuses not only on security. There is also some specific experience in HRIA, but it is different from what is required in the AI Act. The typical use of the HRIA is as a policy tool, not as a legal requirement to show that appropriate measures have been taken to better the situation, there is no focus on the threshold of risk and how to reduce the risk.

For the AI Act it is very difficult to set standards (principles-based legislation), because there is a variety of applications. It is only possible to define a methodology. The HRIA is not focused on evaluating whether a product is ok to market, but it is a design tool.

The risk assessment is performed through the evaluation of likelihood and severity. The likelihood is the probability of the adverse event. The severity is the gravity of the adverse event. The likelihood takes into account the exposure (how many people are exposed to the risk). The severity is linked to the gravity of the prejudice in terms of impact on fundamental rights. The impact on fundamental rights should be considered autonomous for each fundamental right, the impact on a given fundamental right cannot be compensated by a lower impact / beneficial effect on another fundamental right.

In order to evaluate the impact, one can use the scores obtained via the system described above (a function of likelihood and severity) to plot a radial graph, where each axis (not necessarily

orthogonal) is a fundamental right. Mitigation measures can be considered, but it is important to evaluate when the impact is justified by a legal balance of interests. Then the steps evaluation → mitigation can be repeated in a circular process.

AI regulation is not only a matter of data protection and fundamental rights, but also a matter of ethics of technology. The fact that now we are discussing about the AI Act (useful in terms of security, impact on fundamental rights) does not undermine the importance of the ethical aspects of AI (where do we want to go?). The impact on fundamental rights alone cannot answer this question. A piece of technology can be perfect in terms of fundamental rights, while being problematic in terms of how it shapes society (tech is not neutral). In this sense, the ethical debate provided a lot of guidelines, which can be used to make a better design. The main limit is that guidelines focus on general principles, rather than how to implement these principles. Another approach is based in questionnaires to detect what are the values in a community (bottom-up civic participation). This has the same problem, ie it cannot result on technical guidelines but only on general principles.

How do AI developers deal with the ethical risks? Some companies have created ethical boards and have some transparency on their effect on the business. An example is the Facebook ethical board. However, there is an obvious conflict of interests. In the case of Facebook, the oversight board can only have an impact on the content ban, not on the very core of Facebook, its structure which strongly influences the content that is posted on Facebook. Another example is Axon, an arms manufacturer. Axon created a board that can give non-binding recommendations. The Axon ethics board can hear employees in anonymity. This can be more effective rather than having a “detached” board that meets once or twice a year and has no contact with the employees. In the example of Axon, the ethical board interacts with employees. There are problems in this system too: specifically, the resources (money and information) that is given to the board. Furthermore, if the board is bound by a NDA, the discussion on ethics cannot be made public and will be limited in the sources. Some companies have a board, but they do not release any information on what it does and how they impact the business. Some companies may say that they have an ethics board, but they have no transparency at all, not even about the members. It is interesting to make a comparison with the medical ethics. We have laws that require ethics evaluation. This experience is something we can look at in order to copy some ideas to implement in AI.

Finally, the role of civic (bottom-up) engagement can help to model the design of a product so that its ethics are shaped to match the current social ethics. To design engagement, it is important to make sure that everyone can participate without prejudice. Participation methods require the assistance of social scientists, to be designed carefully and effectively. It is important that participants understand some technical aspects of what will be decided. Participation methods always carry the risk of “participation washing” and the bias induced by voluntary participation.

13.2 Exam question example (Mantelero)

A national border control authority aims to develop an AI solution to speed up border control procedures, mainly with regard to foreigners. The intention is to empower border agents to increase the accuracy and efficiency of border interviews, by using a webcam to answer questions from a computer animated board guard, personalized to the traveler’s gender, ethnicity and language.

The AI will analyze the micro-expressions of travelers to detect whether they are lying during the interview at boarding control. This technology is linked to facial recognition

technology. The system is designed to detect false responses by observing non-verbal behavior. Travelers will therefore be filmed using the video cameras while AI analyzes the respondent's facial micro-gestures to detect deceptive behavior.

What are the main issues to be considered in this project with regard to AI and data protection? Is there any way to address them?

My answer:

In terms of data protection, it is important to consider two aspects: (1) whether the personal data involved in training the AI was processed with the proper legal basis and (2) how the traveler's data is processed. Regarding point (1), it is important that the subjects involved in the training dataset are aware of the use of their personal data in the AI context, so, for example, it would be illegal to use past traveler's personal data in order to train the AI, unless they were informed and their free and explicit consent was given. Only after a dataset with these characteristics has been found or collected, it is possible to proceed with the training. Regarding point (2), the traveler's data must be processed only for those purposes that are necessary to the border police to perform its tasks. Presuming that the AI has been correctly trained to address the task at hand, the processing can legitimately consist in the analysis of the video by the AI model; the results of this analysis, however, should be used only for determining the right of transit of the given traveler. It is important to note that the use of AI, at the moment, is not considered necessary to perform the tasks of the border police, therefore any data processing that would not occur in the absence of the AI system (eg being included in the training dataset) should be subordinated to an explicit consent and cannot be justified by the public role of the border police.

In terms of ethics of AI, and its impact on human rights, the question is much more complex. The risks of implementing such a solution are several and are related to the possibility that the travelers' right of transit is illegally restricted. There exists a possibility that the system would not work for some under-represented subjects, who are not limited to those subjects that belong to typically recognized minorities, but also to subjects who are different from others in the training dataset with respect to any significant feature. It is important that the fundamental right of these subjects to a fair evaluation of their statements and documents is preserved. It is also important that the model does not increase the probability of some deceptive subjects to clear the border control, which could be the case especially if some irrelevant features in the training dataset are spuriously associated with good intentions. One must assume that these sort of bias in the training dataset exist and cannot be removed altogether, and therefore that the AI system itself will preserve the bias. A possible mitigation strategy is to (1) use a very conservative model, which has a high likelihood of generating false positives to deceptive behavior, and (2) ensuring that all passengers that are classified as "deceptive" by the AI are re-routed to a human-based interview where they can repeat or integrate the interview without discrimination. Some ideas to increase the empathy of border agents towards those subjects can be evaluated; as an example, agents could be requested to pass the AI border control as part of their training, and see for themselves that it can make mistakes.

Discussion in class:

Public interest legitimates the processing of personal data, but we must make a balance of interests. First, we must discuss whether it is possible to detect emotions (like lying) to some degree of

reliability. If the system is very weak, the cost of mitigation is more expensive than the cost of implementation, if mitigation is even possible.

Furthermore, this case rises a question of human dignity. According to Mantelero, talking with an avatar is detrimental for human dignity (this could be considered a core value of our culture).

Notice how the discussion is so much shorter than the answer I tried to write.

14 Io vetrai, tu vestrasti, egli

«Vuolsi così colà dove si puote
ciò che si vuole, e più non dimandare».

Professor Vetrò informs Caronte on the true logic behind the solution to his exercises.

I have decided not to write any notes on this part for the following two reasons. The first is that the part of professor Vetrò has been recorded integrally, so one could just watch it on the course website. Besides, most of the lectures are devoted to solving exercises, so it's really not that much work. The second reason is condensed in the quote at the beginning of this chapter.

In the hope that the reader has a sense of humor.